Natalyx MVP Fixes

Work Package 13: Deployment, cloud gates, and PHI readiness

L. Rhodes (plan owner) - A. Zhao (technical review requested)

2026-07-10

Contents

1 Work Package 13: Deployment, cloud gates, and PHI readiness **2**

1.1 Purpose and outcome 2

1.2 Verified current-state evidence 3

1.3 Architecture and contracts 3

1.4 Explicit PR sequence 8

1.5 Cross-repository coordination 24

1.6 Test and acceptance matrix 25

1.7 Risks and decisions 25

1.8 Existing-work salvage 26

1.9 Ownership recommendation 27

1.10 Definition of done 27

1 Work Package 13: Deployment, cloud gates, and PHI readiness

Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

Plan	Value
Work package	WP13
Plan file	`WP13 - Deployment, cloud gates, and PHI readiness.md`
Proposed PRs	P13-01, P13-02, P13-03, P13-04, P13-05, P13-06, P13-07
Inspection snapshot	2026-07-10 20:12 America/New_York

1.1 Purpose and outcome

Problem. The dev endpoint is presently 503, deployments do not prove application readiness, and test/deploy success cannot establish real-user or PHI readiness.

Why this package exists. It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

Completed outcome. Known-revision diagnostics, guarded rollback/evidence capture, automated synthetic A1/A2 journeys, and explicit B1/B2 operational/privacy/PHI go/no-go packets.

Explicit non-goals.

- No deployment in this planning task

- No real user before B1
- No PHI before B2
- No compliance claim from green CI

1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

ID	Class	Repository / ref	File, construct or location	Finding
E-001	verified	live dev / 2026-07-10 20:12 America/New_York	https://dev.app.natalyx.health/ and /health	Both requests returned HTTP 503 from awselb/2.0; the deployed participant app is not presently usable.
E-002	verified limitation	AWS dev / 2026-07-10 20:12 America/New_York	aws sts get-caller-identity –profile natalyx-dev	Local AWS SSO was expired, so current ECS desired/running counts and task revision were not independently verified. Gate A0 must refresh access and capture them.
E-007	verified	app / feature/byos-node0-consolidation@84a5a84	app/storage/schema.py:133,353-880	Schema ownership is a monolithic init_db/ensure_column routine with inline CREATE TABLE/ALTER TABLE and no ordered migration/version/checksum ledger.
E-008	verified	app / origin/main@fdf2bb4	app/main.py:295-313	Cloud startup validates auth/storage then calls storage.init_db in-process; readiness is not separated from migration execution.
E-026	verified	app / origin/main@fdf2bb4	app/main.py:145-148	/healthz returns only status ok when the process can serve; it does not report revision, database, migration, intelligence, storage, or readiness.
E-027	verified	app/infra / origin/main@fdf2bb4 / infra main@fec515f	app .github/workflows/aws-app-deploy.yml:60-190; infra CDK workflow	Deployment reads infra-owned SSM contracts and guards billable ECS updates, but successful image build/contract smoke does not prove a healthy service revision.

1.3 Architecture and contracts

- Health, readiness, revision, dependency, migration, and safe configuration signals are distinct.
- Every cloud gate has prerequisites, evidence, owner, verifier, and failure/rollback response.
- B2 requires formal security/privacy/compliance evidence and human go/no-go; it is not a software test result.

Contract area	Package rule
Ownership boundary	`.github`, `app`, `infra`; repository-specific PRs remain separate.
Entities/state	No new runtime entity; evidence/coordination only.
Authorization	Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority.
API/service	Health/readiness endpoints with stable machine-readable reasons.
Storage	RLS policies and least-privilege grants under a reviewed migration.
Audit	Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads.
Failure	Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence.
Observability	Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging.
Compatibility	Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair.
Privacy/PHI	Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2.

1.3.1 Programme gate summary

1.3.2 Gate A0 - Infrastructure recovery and known-revision health

Field	Contract
Prerequisite PRs/gates	P01-01, P02-02, P13-01, P13-02
Prerequisite decisions	D-MIG-01, D-OPS-01
Responsible owner	Alan
Verifier	Luke

Acceptance matrix:

- ☐ CloudFormation/ECS/ALB state is captured from refreshed dev credentials and is stable.
- ☐ The running app and intelligence image SHAs/task definitions are known and map to reviewed commits.
- ☐ Liveness and readiness are both healthy; PostgreSQL, migrations and required private intelligence dependencies pass their bounded checks.
- ☐ A synthetic unauthenticated health request and authenticated minimal route succeed without PII/PHI.
- ☐ Rollback or forward-repair path is rehearsed and the prior compatible revision is identified.

Required evidence:

- AWS account/region and stack/service snapshots
- ALB status and target health
- image SHA/task definition
- readiness JSON/log correlation
- CI/PostgreSQL artifacts
- rollback rehearsal

Failure and rollback response. Do not proceed to participant validation. Freeze live updates, retain evidence, restore the known compatible image/schema or forward-repair under the approved runbook, and keep the programme gate blocked.

1.3.3 Gate A1 - Synthetic core participant journey

Field	Contract
Prerequisite PRs/gates	P02-04, P03-01, P03-02, P03-04, P04-01, P04-02, P04-03, P05-01, P05-02, P05-03, P11-03, P13-03
Prerequisite decisions	D-AUTH-01, D-AUTH-02, D-DATA-01, D-DATA-02, D-DATA-03
Responsible owner	Alan
Verifier	Luke

Acceptance matrix:

- ☐ A new synthetic IP signs up, is deterministically routed, enters Node 0 Free and no paid case is created.
- ☐ Candidate/outreach data remains IP-attributed and provisional; no score or answer becomes GC/provider truth.
- ☐ A synthetic GC begins a low-risk claim, binds identity/consent and sees only the allowed workspace projection.
- ☐ Cross-role negative tests prove class-2 IP assertions and class-4 GC-private answers do not leak.
- ☐ Both roles log out/in/resume and complete the mobile journey at tested widths.
- ☐ Known revision, audit events, correlation IDs and sanitized evidence are attached to the gate item.

Required evidence:

- A1 synthetic run artifact
- separate IP/GC subject IDs (synthetic only)
- authorization matrix results
- mobile screenshots/accessibility output
- audit event trace
- database invariant queries

Failure and rollback response. Stop before Complete, commercial or paid-case validation. Revert/disable the failing participant feature flag or deploy the known A0 revision; preserve synthetic data only for defect diagnosis, then purge under the runbook.

1.3.4 Gate A2 - Synthetic commercial, promotion, billing and document journey

Field	Contract
Prerequisite PRs/gates	P03-03, P06-01, P06-02, P06-03, P07-01, P07-02, P07-03, P07-04, P08-01, P08-02, P08-03, P08-04, P09-01, P09-02, P09-03, P09-04, P09-05, P10-01, P10-02, P10-03, P10-04, P11-01, P11-02, P11-04, P12-01, P12-02, P13-04
Prerequisite decisions	D-COM-01, D-COM-02, D-COM-03, D-COM-04, D-PAY-01, D-COM-05, D-COM-06, D-COM-07, D-COM-08, D-DOC-01, D-DOC-02, D-PROV-01, D-AI-01
Responsible owner	Alan
Verifier	Luke

Acceptance matrix:

- ☐ Synthetic Complete entitlement does not itself create a case and records its commercial configuration version/credit.
- ☐ Only byos.workspace_promotion_authorized.v1 authorizes exactly one enrollment_pending case; callbacks/redirects/replays create none/duplicates.
- ☐ Recipient-bound paid-case invitation and consent grant correct membership; activation waits for approved evidence.
- ☐ Enrollment/activation/milestone/credit/refund ledgers reconcile, including duplicate and out-of-order provider events.
- ☐ Synthetic files follow upload/quarantine/scan/available/download/replacement/revocation/recovery and never become public.
- ☐ Provider packet contains only purpose-allowed consented sources; intelligence scopes and proposals do not upgrade truth.

Required evidence:

- A2 synthetic run artifact
- processor simulator event ledger
- promotion idempotency query
- invoice/refund explanations
- S3/KMS/IAM/quarantine assertions
- provider snapshot checksum
- Ask/proposal safety evals

Failure and rollback response. Disable commercial/document/provider features, retain free/safety content, prevent live money or real documents, reconcile synthetic ledger inconsistencies, and restore the A1-known revision or forward-repair as approved.

1.3.5 Gate B1 - Real-user and PII beta readiness

Field	Contract
Prerequisite PRs/gates	A2, P12-03, P13-07
Prerequisite decisions	D-PHI-01, D-PHI-02
Responsible owner	Luke
Verifier	External/TBD

Acceptance matrix:

- ☐ A written B1 data-classification boundary permits named PII and expressly prohibits PHI/clinical documents.
- ☐ Named beta users, support/on-call, access review, incident response, backup/restore, retention/deletion and complaint routes are ready.
- ☐ Security/privacy review has no unresolved critical finding; vendors handling PII are approved.
- ☐ A2 evidence is current for the exact candidate revision and rollback/feature-disable controls are operational.
- ☐ Consent/privacy/terms copy is approved and data-subject correction/deletion workflows are testable.

Required evidence:

- Signed B1 checklist
- data inventory/classification
- access review
- incident tabletop
- backup/restore result
- vendor register
- current A2 bundle

Failure and rollback response. No real-user invitation. Continue synthetic-only, close control gaps, invalidate stale evidence and re-run the exact affected reviews/tests before a new go/no-go.

1.3.6 Gate B2 - PHI readiness and formal go/no-go

Field	Contract
Prerequisite PRs/gates	B1, P13-05, P13-06, P13-07
Prerequisite decisions	D-PHI-01, D-PHI-02
Responsible owner	Luke
Verifier	External security/privacy/compliance reviewers

Acceptance matrix:

- ☐ Formal PHI data flows, risk assessment, policies, BAAs/vendor controls, least privilege, audit/log retention, encryption/key management, incident/breach response and backup/restore are approved.

☐ Application, infrastructure, document, provider and intelligence threat models have current evidence and no unresolved critical/high risk without accepted exception.
☐ Operational staff training, access provisioning/deprovisioning, monitoring, support and emergency stop are complete.
☐ The exact release passed A2 and B1 revalidation; a signed human go/no-go records scope, date, evidence versions and approvers.
☐ The gate states explicitly that testing/deployment alone did not establish HIPAA/PHI readiness.

Required evidence:

- Signed go/no-go
- risk/security/privacy assessments
- BAA/vendor evidence
- access/log/incident/backup controls
- penetration/security testing
- training/operations evidence
- current technical gate bundles

Failure and rollback response. PHI remains prohibited. Keep B1 PII scope only if still independently valid; disable any PHI-capable upload/context path, remediate, and repeat formal review.

1.4 Explicit PR sequence

Order	ID	Title	Repository	Dependencies	Gate	Size	Readiness
1	P13-01	Expose known-revision health, readiness, and dependency diagnostics	app	P01-01	A0	Large	Dependencies unmet
2	P13-02	Harden guarded deployment, rollback, and evidence capture	infra	P01-01, P13-01	A0	Large	Dependencies unmet
3	P13-03	Automate synthetic A1 core participant journey verification	app	P03-02, P04-03, P05-03, P11-03, P13-02	A1	Large	Dependencies unmet
4	P13-04	Automate synthetic A2 commercial and document journey verification	app	P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03	A2	Exceptional	Dependencies unmet

Order	ID	Title	Repository	Dependencies	Gate	Size	Readiness
5	P13-05	Enforce case RLS and a non-owner PostgreSQL runtime	app	P02-03, P03-03, P04-03, P09-05, P10-02	B2	Exceptional	Dependencies unmet
6	P13-06	Harden B1/B2 backups, audit, alarms, and cohort controls	infra	P09-02, P13-02, P13-05	B2	Exceptional	Dependencies unmet
7	P13-07	Publish B1 and B2 privacy, PHI, and operational go-no-go runbooks	.github	P13-04, P13-05, P13-06	B2	Large	Blocked by decision

1.4.1 P13-01 - Expose known-revision health, readiness, and dependency diagnostics

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A0 / Large / Dependencies unmet
Dependencies	P01-01
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	Current /healthz, direct 503 evidence

1.4.1.1 Objective Separate liveness, readiness, build revision, migration, database, intelligence, storage, and safe-config status so Gate A0 can identify the actual failing dependency.

1.4.1.2 Scope

- Unauthenticated minimal liveness
- Safe readiness/dependency checks
- Revision/config identifiers without secrets
- Startup failure classification

1.4.1.3 Explicit non-goals

- No PHI/PII in diagnostics
- No dependency mutation

1.4.1.4 Expected files or modules

- `app/health.py`
- `app/main.py`
- `app/dev_diagnostics.py`
- `tests/python/test_health.py`

1.4.1.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	Health/readiness endpoints with stable machine-readable reasons.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.1.6 Tests and validation Objective tests:

- DB/migration/intelligence/storage failures
- timeout
- redaction
- known SHA
- ALB contract

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A0** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.1.7 Diagnostics and observability Structured startup/readiness logs.

1.4.1.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.1.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.1.10 Dependencies and parallel work Hard dependencies: P01-01. Parallel opportunities: P13-03, P13-04, P13-05, P13-06, P13-07

1.4.1.11 Objective acceptance criteria

- ☐ Separate liveness, readiness, build revision, migration, database, intelligence, storage, and safe-config status so Gate A0 can identify the actual failing dependency.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.1.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	runtime operations, FastAPI, observability
Higher-capability review	Mandatory before merge

1.4.2 P13-02 - Harden guarded deployment, rollback, and evidence capture

Field	Plan
Repository / base	`infra` (`main`)
Gate / size / readiness	A0 / Large / Dependencies unmet
Dependencies	P01-01, P13-01
Blocking decisions/checkpoints	D-OPS-01
Source / salvage	Existing guarded app/infra workflows

1.4.2.1 Objective Make app/intelligence deployment record the image SHA/task definition, wait for health, capture non-secret failure evidence, and roll back or stop safely under explicit guards.

1.4.2.2 Scope

- Known-revision deploy and service stabilization
- Least-privilege one-off migration task identity
- Migration/app compatibility preflight
- Rollback/forward-repair decision
- Evidence artifact

1.4.2.3 Explicit non-goals

- No automatic billable activation
- No planning-task deployment

1.4.2.4 Expected files or modules

- `.github/workflows/cdk.yml`
- `lib/stacks/platform-stack.ts`
- `lib/constructs/migration-task.ts`
- `scripts/verify-service-health.*`
- `docs/runbooks/deploy-rollback.md`

1.4.2.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	Guarded workflow/alarms/contracts; default desired counts remain safe.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.2.6 Tests and validation Objective tests:

- CDK/workflow contract
- unhealthy revision
- rollback compatibility
- billable flag false
- missing SSM output

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **A0** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.2.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.2.8 Rollout Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

1.4.2.9 Rollback or forward repair Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

1.4.2.10 Dependencies and parallel work Hard dependencies: P01-01, P13-01. Parallel opportunities: P13-04, P13-05, P13-07

1.4.2.11 Objective acceptance criteria

- ☐ Make app/intelligence deployment record the image SHA/task definition, wait for health, capture non-secret failure evidence, and roll back or stop safely under explicit guards.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.2.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	AWS ECS/ALB, GitHub Actions, rollback operations
Higher-capability review	Mandatory before merge

1.4.3 P13-03 - Automate synthetic A1 core participant journey verification

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A1 / Large / Dependencies unmet
Dependencies	P03-02, P04-03, P05-03, P11-03, P13-02
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	Existing synthetic sandbox/scenario utilities

1.4.3.1 Objective Run the entry, auth, Node 0 Free, low-risk GC claim, role separation, resume, and mobile journey against a known dev revision and publish a redacted A1 evidence bundle.

1.4.3.2 Scope

- A1 core IP/GC workspace journey
- Known SHA and evidence bundle
- Role/authorization negative cases
- Cleanup of synthetic records

1.4.3.3 Explicit non-goals

- No payment/promotion/document journey
- No real user
- No PHI
- No gate auto-approval

1.4.3.4 Expected files or modules

- `tests/cloud/a1/`
- `scripts/run_synthetic_a1.py`
- `.github/workflows/synthetic-cloud-gates.yml`
- `docs/runbooks/synthetic-gates.md`

1.4.3.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	Manual/guarded A1 synthetic runner with immutable artifact summary.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.3.6 Tests and validation Objective tests:

- Happy path
- authorization denial
- retry/duplicate
- logout/login
- mobile
- dependency outage
- cleanup failure

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.3.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.3.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.3.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.3.10 Dependencies and parallel work Hard dependencies: P03-02, P04-03, P05-03, P11-03, P13-02. Parallel opportunities: P13-01, P13-05, P13-06, P13-07

1.4.3.11 Objective acceptance criteria

- ☐ Run the entry, auth, Node 0 Free, low-risk GC claim, role separation, resume, and mobile journey against a known dev revision and publish a redacted A1 evidence bundle.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.3.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	browser automation, AWS dev operations, end-to-end testing
Higher-capability review	Mandatory before merge

1.4.4 P13-04 - Automate synthetic A2 commercial and document journey verification

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A2 / Exceptional / Dependencies unmet
Dependencies	P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	Payment document smoke paths, A1 harness

1.4.4.1 Objective

Extend the known-revision cloud harness with commitment, funding, exactly-once promotion, case invite, activation, billing, refund, document, handoff, Ask/Learn, and recovery evidence.

1.4.4.2 Scope

- A2 commercial/promotion/billing/document journey
- Duplicate/retry/refund/failure cases
- Known SHA and evidence bundle
- Synthetic cleanup

1.4.4.3 Explicit non-goals

- No real money
- No real user
- No PHI
- No gate auto-approval

1.4.4.4 Expected files or modules

- `tests/cloud/a2/`
- `scripts/run_synthetic_a2.py`
- `.github/workflows/synthetic-cloud-gates.yml`
- `docs/runbooks/synthetic-gates.md`

1.4.4.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	Guarded A2 synthetic runner; uses processor simulator and synthetic documents only.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.4.6 Tests and validation

Objective tests:

- Funding event exactly once
- promotion replay
- case invite
- milestone/refund

- upload/scan failure
- Ask scope
- rollback evidence

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.4.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.4.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.4.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.4.10 Dependencies and parallel work Hard dependencies: P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03. Parallel opportunities: P13-01, P13-02, P13-05, P13-06

1.4.4.11 Objective acceptance criteria

- ☐ Extend the known-revision cloud harness with commitment, funding, exactly-once promotion, case invite, activation, billing, refund, document, handoff, Ask/Learn, and recovery evidence.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.4.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke

Role	Recommendation
Required expertise	browser automation, payments testing, AWS dev operations, end-to-end testing
Higher-capability review	Mandatory before merge

1.4.5 P13-05 - Enforce case RLS and a non-owner PostgreSQL runtime

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	B2 / Exceptional / Dependencies unmet
Dependencies	P02-03, P03-03, P04-03, P09-05, P10-02
Blocking decisions/checkpoints	D-PHI-01
Source / salvage	case-shell.md current app-layer-only/RLS gap

1.4.5.1 Objective Move app runtime to a least-privilege non-DDL database role and enforce tenant/case membership policies with RLS/FORCE RLS before any PHI gate can open.

1.4.5.2 Scope

- Runtime/migrator role separation
- RLS/FORCE RLS on case/participant/document/commercial tables
- Transaction-local subject/org/case context
- Policy-negative and pool-reset tests

1.4.5.3 Explicit non-goals

- No PHI gate activation
- No trust in app guards alone
- No runtime DDL

1.4.5.4 Expected files or modules

- `migrations/versions/*_case_rls.py`
- `app/storage/connection.py`
- `app/storage/session_context.py`
- `tests/security/test_case_rls.py`
- `docs/security/rls.md`

1.4.5.5 Change map

Area	Planned change
Schema/model	RLS policies and least-privilege grants under a reviewed migration.

Area	Planned change
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	Apply through the named versioned migration; no ad-hoc startup DDL. Backfill is none unless explicitly listed in scope.
Security/privacy	Database denies cross-case/ambient reads even if an app guard is missed.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.5.6 Tests and validation

Objective tests:

- Cross-case/role denial
- connection-pool context reset
- migrator versus runtime grants
- background worker scope
- previous app compatibility during rollout

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **B2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.5.7 Diagnostics and observability

Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.5.8 Rollout

Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.5.9 Rollback or forward repair

Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.5.10 Dependencies and parallel work

Hard dependencies: P02-03, P03-03, P04-03, P09-05, P10-02. Parallel opportunities: P13-01, P13-02, P13-03, P13-04

1.4.5.11 Objective acceptance criteria

- ☐ Move app runtime to a least-privilege non-DDL database role and enforce tenant/case membership policies with RLS/FORCE RLS before any PHI gate can open.

- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.5.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	PostgreSQL RLS, connection pooling, security architecture
Higher-capability review	Mandatory before merge

1.4.6 P13-06 - Harden B1/B2 backups, audit, alarms, and cohort controls

Field	Plan
Repository / base	`infra` (`main`)
Gate / size / readiness	B2 / Exceptional / Dependencies unmet
Dependencies	P09-02, P13-02, P13-05
Blocking decisions/checkpoints	D-PHI-01, D-PHI-02
Source / salvage	Existing audit/backup/platform stack constructs

1.4.6.1 Objective Add the infrastructure evidence and controls required for a named PII beta and later PHI review: backup/restore, data-event audit, least privilege, alarms, log retention, cohort disable, and emergency stop.

1.4.6.2 Scope

- RDS/S3 backup and restore evidence hooks
- CloudTrail S3 data events and access alarms
- Runtime/migrator/task-role least privilege
- Cohort disable and PHI gate kill switch
- Log retention/redaction contracts

1.4.6.3 Explicit non-goals

- No production/PHI activation
- No evidence claim without restore/tabletop

1.4.6.4 Expected files or modules

- `lib/stacks/platform-stack.ts`
- `lib/constructs/audit.ts`
- `lib/constructs/backup.ts`
- `test/security-controls.test.ts`
- `docs/runbooks/security-operations.md`

1.4.6.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	Guarded, cost-aware controls with explicit dev defaults and documented operational owners.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.6.6 Tests and validation Objective tests:

- CDK policy assertions
- restore drill
- alarm path
- access-log redaction
- cohort/PHI gate disable
- role boundary

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **B2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.6.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.6.8 Rollout Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

1.4.6.9 Rollback or forward repair Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

1.4.6.10 Dependencies and parallel work Hard dependencies: P09-02, P13-02, P13-05. Parallel opportunities: P13-01, P13-03, P13-04

1.4.6.11 Objective acceptance criteria

- ☐ Add the infrastructure evidence and controls required for a named PII beta and later PHI review: backup/restore, data-event audit, least privilege, alarms, log retention, cohort disable, and emergency stop.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.6.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	AWS security, backup/restore, CloudTrail/CloudWatch, IAM
Higher-capability review	Mandatory before merge

1.4.7 P13-07 - Publish B1 and B2 privacy, PHI, and operational go-no-go runbooks

Field	Plan
Repository / base	`.github` (`main`)
Gate / size / readiness	B2 / Large / Blocked by decision
Dependencies	P13-04, P13-05, P13-06
Blocking decisions/checkpoints	D-PHI-01, D-PHI-02
Source / salvage	Natalyx compliance/company records by reference, all gate evidence

1.4.7.1 Objective Create the programme evidence index and explicit human approval packets for PII beta (B1) and PHI readiness (B2), linking rather than duplicating controlled company/compliance records.

1.4.7.2 Scope

- Data classification and real-user boundary

- Access/logging/incident/backup/vendor/compliance evidence
- Named approvers and expiry/revalidation
- Rollback/stop response

1.4.7.3 Explicit non-goals

- No legal/compliance self-certification
- No PHI activation by merge

1.4.7.4 Expected files or modules

- `natalyx-repair-program/gates/B1-real-user-pii.md`
- `natalyx-repair-program/gates/B2-phi-go-no-go.md`
- `natalyx-repair-program/evidence-index.md`

1.4.7.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Controlled go/no-go checklists and evidence links only.

1.4.7.6 Tests and validation Objective tests:

- Evidence completeness review
- tabletop incident
- access review
- backup/restore evidence
- external security/privacy sign-off

Local validation:

- `git diff --check`
- `python scripts/validate_programme.py`

Cloud validation: run only through Gate **B2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.7.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.7.8 Rollout Merge only after document/sign-off checks; it changes no runtime. Regenerate the Drive review package from the same canonical data; reactivate tracking only after approval.

1.4.7.9 Rollback or forward repair Correct the canonical data and regenerate; do not rewrite implementation history.

1.4.7.10 Dependencies and parallel work Hard dependencies: P13-04, P13-05, P13-06. Parallel opportunities: P13-01, P13-02, P13-03

1.4.7.11 Objective acceptance criteria

- ☐ Create the programme evidence index and explicit human approval packets for PII beta (B1) and PHI readiness (B2), linking rather than duplicating controlled company/compliance records.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.7.12 Ownership and review

Role	Recommendation
DRI	Luke
Implementer	Joint (proposed; pending consolidated-plan sign-off)
Reviewer	External/TBD
Final approver	Luke
Required expertise	privacy/security governance, operations, compliance
Higher-capability review	Mandatory before merge

1.5 Cross-repository coordination

Repository	Authority after merge
`.github`	programme/governance evidence and future approved tracking
`app`	routing, validation, authorization, participant/case/workflow truth, PHI policy and commercial domain
`infra`	AWS resources, IAM/KMS/network/deployment/backup/audit contracts

Merge order inside this package: `P13-01` → `P13-02` → `P13-03` → `P13-05` → `P13-06` → `P13-04` → `P13-07`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

1.6 Test and acceptance matrix

Test dimension	Method	Objective result
Happy path	Known revision; ALB/ECS/dependency health; Rollback; Synthetic A1/A2; PII controls; PHI go/no-go evidence	Expected state/event/UI and named evidence are produced once.
Authorization failure	Wrong/no subject, role, membership, purpose or consent	403/404 as appropriate; no write or data leak; audit safe failure.
Role differences	Separate IP, GC, operator, provider/service identities	Only the approved lens/projection/actions appear.
Retries/duplicates	Repeat same canonical request/event	Original result returned; no duplicate membership/case/invoice/document/event.
Concurrency	Two writers/claimants/migrators/workers	One valid transition; loser receives deterministic stale/conflict response.
Stale state	Old revision/config/terms/token/artifact	Fail closed or approved compatibility behavior; never silent coercion.
Malformed input	Boundary, encoding, size, enum, redirect and identifier corpus	Validation before side effects; safe error.
Unavailable dependency	Database, intelligence, processor, S3/scanner or auth unavailable	Explicit degraded/blocked behavior; no hallucinated success.
Partial failure	Crash between external effect, DB transaction and outbox	Retry/forward repair converges from durable evidence.
Logout/login/resume	Session expires/restarts mid-flow	Return to authorized current state; no query/link authority.
Mobile/accessibility	320/375/768 widths, keyboard, focus, reduced motion	Core task completes with truthful state and no clipped controls.
Synthetic cloud	Known dev revision and synthetic identities/data	Gate artifact records SHA, dependency status, audit and cleanup.
Audit/observability	Inspect events/metrics/logs	Versions, actor/authority, correlation and reason present; no sensitive payload.

1.7 Risks and decisions

Type	ID / risk	Owner	Affected PRs / latest point	Treatment
Blocking/product/compliance decision	D-OPS-01 - Select the revision/schema pair to recover dev, roll-back/forward-repair criteria and evidence owner.	Luke	P13-02; Before Gate A0 recovery action	D-OPS-01 - Use a tested immutable image and compatible schema; do not deploy from dirty or draft branches.
Blocking/product/compliance decision	D-PHI-01 - Approve data classification, vendors/BAAs, encryption/logging/access/incident/backup controls and prohibited data at each gate.	Luke	P09-01, P09-02, P09-05, P13-05, P13-06, P13-07; Before B1 for PII scope; before B2 for PHI	D-PHI-01 - B1 remains PII-only; B2 requires formal external security/privacy/compliance evidence.
Blocking/product/compliance decision	D-PHI-02 - Name security/privacy/compliance approvers, evidence recency, exception authority and revalidation cadence.	Luke	P13-06, P13-07; Before B1	D-PHI-02 - Luke is product go/no-go; independent qualified reviewers own their control attestations.
Implementation risk	Unknown running revision	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Rollback incompatible with schema	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Synthetic success overclaimed	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	PHI enabled without organizational controls	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan

1.8 Existing-work salvage

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
No direct source	-	Build from approved contracts/evidence	Package PRs	New implementation	N/A

Package source inventory:

- Existing guarded AWS workflows and SSM contracts
- Current healthz
- Prior app/infra/intelligence AWS migration PR evidence

1.9 Ownership recommendation

Alan owns technical recovery/validation; Luke accepts gates and PHI boundary. External security, privacy, compliance, finance/payment, and clinical/legal review as applicable.

PR	DRI	Implementer	Reviewer	Final approver	External/high-capability review
P13-01	Alan	Alan (proposed)	Luke	Luke	Mandatory
P13-02	Alan	Alan (proposed)	Luke	Luke	Mandatory
P13-03	Alan	Alan (proposed)	Luke	Luke	Mandatory
P13-04	Alan	Alan (proposed)	Luke	Luke	Mandatory
P13-05	Alan	Alan (proposed)	Luke	Luke	Mandatory
P13-06	Alan	Alan (proposed)	Luke	Luke	Mandatory
P13-07	Luke	Joint (proposed)	External/TBD	Luke	Mandatory

Luke decides product/lifecycle/commercial/privacy/PHI/provider policy and accepts gates. Alan proposes implementation design, decomposition, migrations, code, tests, rollout and repair. This is a recommendation pending Alan's review/sign-off, not a compulsory assignment.

1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is fail-closed or explicitly degraded.
- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.

- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.